GOOGLE CLOUD AI SECURITY & GOVERNANCE PLATFORM

Aseguramiento, Gobernanza y Auditoría Continua de IA

Plataforma integral para evaluar, auditar y blindar arquitecturas de Inteligencia Artificial Empresarial (GenAI, LLMs, Agentes Autónomos y RAG) bajo estándares mundiales **OWASP AISVS v1.0** e **ISO/IEC 42001**.

OWASP AI-SVS V1.0 (12 CAPÍTULOS) | ISO/IEC 42001:2023 | GCP LIVE SCANNER | MOTOR DUAL: GEMINI + OPENROUTER | DEVSECOPS & CI/CD

EL PROBLEMA A RESOLVER

El Punto Ciego de Seguridad en la Adopción de GenAI

Las empresas están desplegando Inteligencia Artificial Generativa a una velocidad sin precedentes, pero sin controles arquitectónicos ni defensas auditables.

⚠ Despliegue Acelerado sin Gobierno

El **13% de las organizaciones** ya reportó brechas en modelos o aplicaciones de IA, y el **97%** de ellas carecía de controles de acceso adecuados para IA (IBM, 2025).

⚠ Superficie de Ataque Inédita

Los pipelines RAG y agentes autónomos introducen nuevos riesgos críticos: **Prompt Injection Indirecta**, **Envenenamiento de Embeddings**, fugas de contexto y exfiltración de memoria.

⚠ Vacío entre CISO y Científicos de Datos

Los equipos de ciberseguridad carecen de herramientas especializadas para entender grafos de agentes y bases vectoriales; los desarrolladores de IA desconocen los marcos normativos formales.

Falta de Estándares Aplicados

A pesar de existir marcos como **OWASP AISVS** e **ISO 42001**, las organizaciones no cuentan con software automatizado que traduzca cientos de controles teóricos en validaciones técnicas de código e infraestructura en la nube.

Proliferación de "Shadow AI"

Uso informal de APIs externas con almacenamiento desprotegido de credenciales maestras, ausencia de cuotas, falta de cifrado en reposo para vectores y registros con información personal identificable (PII).

Fuente: IBM Cost of a Data Breach Report 2025

IMPACTO DE LA NO PREVENCIÓN

El Costo Real de Ignorar la Auditoría Preventiva

Operar sistemas de IA sin aseguramiento formal acarrea consecuencias financieras, legales y operativas devastadoras.

€35M
o 7% de facturación global por multas de la EU AI Act

$4.88M
Costo promedio global de una filtración de datos corporativos (IBM 2024)

13%
de las organizaciones reportó brechas en modelos o apps de IA (IBM 2025)

97%
de ellas carecía de controles de acceso adecuados para IA (IBM 2025)

Exfiltración de Secretos y PII

Inyecciones de prompt capaces de extraer claves de API, secretos de base de datos o historiales crediticios de clientes incluidos inadvertidamente en el contexto del modelo fundacional.

Parálisis Regulatoria y Clausura

Incumplimiento de leyes de protección de datos (LFPDPPP, GDPR) y regulaciones del consumidor (LFPC), derivando en auditorías punitivas, retiro forzoso de productos de IA y litigios civiles.

Pérdida Crítica de Reputación

Alucinaciones tóxicas en agentes de atención a clientes y toma de decisiones discriminatorias o sesgadas que destruyen la confianza del mercado y devaluación de la marca.

NUESTRA SOLUCIÓN

AegisAI: Aseguramiento Integral y Automatizado

Transformamos la auditoría de IA de un proceso manual que toma meses en un análisis asistido por IA que toma minutos.

🛡 Enfoque Proactivo & Shift-Left

AegisAI evalúa los artefactos técnicos (diagramas de flujo, especificaciones de microservicios, configuraciones de prompts y cloud infra) **antes y durante** su puesta en producción.

- Evaluación granular de controles de seguridad en minutos.
- Identificación inmediata de áreas de oportunidad y controles reprobados.
- Enmascaramiento de credenciales en las respuestas de la API.

⚡ Remediación Automatizada & Código Listo

No solo señalamos qué está mal: generamos el **plan de acción técnico**, la arquitectura corregida y las recetas de código para subsanar cada falla.

- Recetas de código en TypeScript, Python y Google Cloud CLI.
- Especificación de arquitectura remediada paso a paso.
- Exportación de informes ejecutivos en PDF de calidad editorial.

1. Diagnóstico Estándar

Contraste matemático contra OWASP AISVS, ISO 42001 y normativas legales mexicanas.

2. Escáner en Vivo GCP

Inspección de proyectos reales de Google Cloud: Vertex AI, Cloud Run, Secret Manager y IAM.

3. Trazabilidad C-Level

Métricas agregadas de postura de seguridad, porcentajes de cumplimiento y auditorías históricas.

MATRIZ NORMATIVA

Cumplimiento Multi-Estándar y Gobernanza Global

Soporte nativo para los estándares de seguridad de IA más exigentes del mundo y capacidad de personalización empresarial.

Estándar / Regulación	Alcance Técnico	Controles Evaluados por AegisAI	Nivel de Cobertura
OWASP AI-SVS v1.0	Estándar de Verificación de Seguridad en Sistemas de IA	12 Capítulos: Gobernanza, Cadena de Suministro, Datos, Arquitectura, Modelos, RAG, Pruebas y Despliegue.	12 CAPÍTULOS · 56 CONTROLES
ISO/IEC 42001:2023	Sistema de Gestión de Inteligencia Artificial (AIMS)	Cláusulas 4 a 10 y Controles del Anexo A: Evaluación de impacto ético, gestión de riesgos de IA y auditoría continua.	54 CONTROLES
Leyes Mexicanas (2026)	Protección al Consumidor (LFPC) y Datos Personales (LFPDPPP)	Transparencia de algoritmos, prevención de publicidad engañosa con IA, derechos ARCO y consentimiento expreso.	28 CONTROLES
Marco BYOF (Personalizado)	*Bring Your Own Framework*	Motor que permite cargar normativas internas organizacionales en JSON con controles ponderados específicos.	EXTENSIBLE

Auditoría Cruzada Unificada: Un mismo proyecto o arquitectura puede ser auditado simultáneamente contra múltiples marcos con un solo clic, consolidando un puntaje global y hallazgos específicos por normativa.

Incluye además el marco EU AI Act (10 controles)

ARQUITECTURA DE SOFTWARE

Arquitectura Desacoplada, Resiliente y Segura

Diseño modular basado en microservicios limpios, middleware de seguridad estricto y motor desacoplado de inferencia.

1. Frontend & Presentación

- **React 19 + TypeScript + Vite**
- Tailwind CSS v4 (Aegis Dark System)
- Gráficos dinámicos con **Recharts**
- Exportación PDF con **jsPDF & AutoTable**
- Estado reactivo local y soporte offline

2. Backend & Seguridad API

- **Node.js + Express + TypeScript**
- Middleware RBAC (`x-admin-token`, `x-api-key`)
- Cabeceras HTTP de seguridad (nosniff, X-Frame-Options, Referrer-Policy)
- Enmascaramiento de credenciales en respuestas de API
- Almacenamiento dual: JSON local + Firestore

3. Motor de IA & Cloud Scanner

- **Google Gemini API** (3.5 Flash / 3.8 Flash)
- **OpenRouter / OpenAI Proxy** desacoplado
- **GCP Live Scanner**: Vertex AI, IAM, Secret Manager, Cloud Run y Storage
- Modelo de respaldo configurable ante saturación

Privacidad y Control de Datos:

Las credenciales se enmascaran en las respuestas de la API (verificado con la prueba automatizada OWASP LLM06). El motor de inferencia es desacoplado: cada organización elige su modelo — Gemini / Vertex AI, cualquier endpoint compatible con OpenAI o modelos locales (Ollama, vLLM)— para mantener sus arquitecturas bajo su control.

OPERACIÓN EN LA PRÁCTICA

El Flujo de Trabajo del Auditor: De la Duda a la Solución

Cómo AegisAI guía al usuario desde la ingesta arquitectónica hasta el blindaje total de la infraestructura.

1. **Ingesta y Contextualización**
   El usuario carga el diagrama, código de infraestructura o descripción del pipeline RAG y selecciona las normativas a evaluar.
2. **Escaneo de Nube en Vivo (Opcional)**
   Si está desplegado en Google Cloud, AegisAI conecta con Vertex AI, Cloud Storage y Secret Manager para verificar configuraciones reales.
3. **Evaluación Algorítmica con IA**
   El motor de inferencia contrasta control por control, evalúa suficiencia técnica y calcula el puntaje global de cumplimiento (0 - 100).
4. **Informe Ejecutivo Interactivo**
   Visualización de gráficos radar de cumplimiento por capítulo, controles aprobados vs. áreas de oportunidad críticas.
5. **Generador de Plan de Acción y Recetas**
   AegisAI genera fragmentos de código y configuración (TypeScript, Python, Terraform) como guía para remediar cada brecha.
6. **Exportación Formal y Descarga**
   Descarga instantánea de informes de auditoría en PDF listos para certificar ante comités de seguridad o reguladores.

DATOS TÉCNICOS DE LA ARQUITECTURA

Especificaciones, Rendimiento y Calidad de Código

Construido bajo estándares industriales de resiliencia, alta disponibilidad y máxima seguridad operativa.

148
Controles evaluables en 5 marcos normativos integrados

10/10
Verificaciones automatizadas OWASP LLM Top 10 aprobadas

0
Claves o secretos expuestos (Verificado con `git-secrets`)

Multi-LLM
Gemini, Claude 3.7, GPT-4o, DeepSeek R1 & Ollama

Infraestructura y Despliegue

- **Contenedorización:** Dockerfile multi-stage optimizado (peso de imagen reducido).
- **Cloud Run:** Autoescalado de 0 a N instancias en Google Cloud, puerto estándar 8080.
- **Secret Manager:** Inyección segura de credenciales en tiempo de ejecución.
- **CI/CD Ready:** Scripts automatizados de pruebas de regresión y verificación de API.

Mecanismos de Resiliencia y Privacidad

- **Modelo de Respaldo:** Modelo alterno configurable ante saturación del proveedor.
- **Aislamiento de Entornos:** Soporte de configuración local segura (`*.local.json`).
- **Modelo a Elección:** Vertex AI / nivel de pago o modelos locales mantienen los datos bajo control de la organización.
- **Modo Offline/Demo:** Capacidad de ejecución autónoma sin dependencias de red externa.

EVOLUCIÓN Y ROADMAP

Siguientes Pasos en el Desarrollo de AegisAI

Hoja de ruta para consolidar el estándar de aseguramiento de Inteligencia Artificial empresarial.

Q4 2026 • CORTO PLAZO

Integración CI/CD Nativa

Creación de **GitHub Actions** y **GitLab CI Runners** oficiales para bloquear automáticamente *pull requests* que introduzcan vulnerabilidades en prompts o pipelines RAG antes de llegar a producción.

Q1 2027 • MEDIANO PLAZO

Auditoría de Agentes Multi-Etapa

Módulo especializado para auditar agentes autónomos complejos (LangGraph, CrewAI, AutoGen): rastreo de llamadas a herramientas, verificación de límites de autorización y prevención de loops infinitos maliciosos.

Q2 2027 • LARGO PLAZO

Auto-Remediación con IaC

Generación automática de módulos de **Terraform** y **Helm Charts** que apliquen automáticamente las recetas de blindaje en Google Cloud, AWS y Azure con un solo comando.

🎯 Conclusión: Seguridad que Habilita la Innovación

AegisAI no busca frenar la adopción de IA, sino proporcionar el **marco de certeza técnica y gobernanza** necesario para que las organizaciones desplieguen modelos y agentes con total confianza, protegiendo sus activos y garantizando su cumplimiento normativo.

Contacto: opensource@aegis-ai.dev • GitHub: github.com/fjhuerta-67/AegisAI